Riskbedömning för SQLi Workshop

Likelihood bedömning
Threat Agent faktorer

Faktor	Poäng	Motivering
Skill Level	3	Grundläggande SQL kunskap räcker, ingen advancerad kunskap behövs för enkla payloads som “OR 1=1” eller UNION SELECT
Motive	9	Hög vinning, tillgång till användardatabas, lösenordshashar samt möjlighet till data förstöring som kan leda till ekonomisk skada eller credentials leak
Opportunity	9	Publikt exponerad API enmdpoint (api/products/:id)
Size	9	Vemsom helst kan attackera, krävs minimal kunskap och mycket tillgänglia verktyg

Threat Agent = (3+9+9+9)/4 = 7.5

Sårbarhersfaktorer

Faktor	Poäng	Motivering
Ease of Discovery	7	Upptäcks enkelt med verktyg som sqlmap eller manuella tester via URL mainipulering
Ease of Exploit	7	Färdiga verktyg med payloads finns, samt mycket publik information kring attacker. Kan utföras direkt i webbläsaren eller konsolen.
Awareness	9	Välkänd sårbarhet i WASP Top 10 (A05:2025 Injection)

Vulnerability = (7+7+9)/3 = 7.7
Likelihood = (7.5+7.7)/2 = 7.6 → **Hög**

Impact bedömning

Teknisk påverkan

Faktor	Poäng	Motivering
Loss of Confidentiality	9	Hela databasen exponeras: Användardata, e-post, hashade lösenord och produktinformation läcks.
Loss of Integrity	9	Data kan ändras eller raderas
Loss of Availability	5	Möjligt med delvis nedtid via DoS liknande attacker men inte fullständigt
Loss of Accountability	7	Svårt att spåra attacker utan loggning, attacker kan även använda proxies.

Impact = (9+9+5+7)/4 = 7.5 → **Hög**

Slutsats
Hög Likelihood x Hög Impact = Kritisk risk. Denna sårbarhet bör prioriteras, då den kan leda till total datakompromiss och dataförlust. Potentiell förlust av kundförtroende och regulatoriska böter (GDPR).

Riskbedömning för XSS Workshop

Likelihood bedömning
Threat Agent faktorer

Faktor	Poäng	Motivering
Skill Level	4	Viss kunskap om HTML/JS behövs för payloads som <img src=x onerror=> men det finns guider online
Motive	8	Hög vinning, eskalering till superadmin ger full kontroll inklusive dataåtkomst
Opportunity	8	Kräver registrering men publikt tillgänglig, ingen stark autentisering
Size	7	Potentiella angripare inkluderar användare eller externa som registrerar sig

Threat Agent = (4+8+8+7)/4 = 6.75

Sårbarhetsfaktorer

Faktor	Poäng	Motivering
Ease of Discovery	6	Upptäcks via inspektion av formulär eller nätverkstrafik (t.ex DevTools)
Ease of Exploit	7	Kan göras via webbläsaren, inga advancerade verktyg behövs
Awarness	9	OWASP Top 10 (A05:2025 Injection för XSS)

Vulnerability = (6+7+9)/3 = 7.3
Likelihood = (6.75+7.3)/2 = 7 → **Hög**

Impact bedömning
Teknisk påverkan

Faktor	Poäng	Motivering
Loss of Confidentiality	8	Användardata exponeras, eskalering ger tillgång till alla användare
Loss of Integrity	9	Roller kan ändras
Loss of Availability	6	Superadmins låses ute via omdirigering, delvis nedtid
Loss of Accountability	6	Delvis spårbart via loggar men anonyma attacker är möjliga

Impact = (8+9+6+6)/4 = 7.25 → **Hög**

Slutsats
Hög Likelihood x Hög Impact = Kritisk risk.Prioritera framför allt privilege escalation, kan ge full systemkontroll. Affärspåverkan, förlorad produktivitet och potentiell dataläckage.

Riskbedömning för Traversal Workshop

Likelihood bedömning
Threat Agent faktorer

Faktor	Poäng	Motivering
Skill Level	3	Grundläggande kunskap om ../ notation räcker, inga specialverktyg
Motive	8	Hög vinning, åtkomst till källkod, konfigfiler eller systemfiler
Opportunity	9	Publika endpoints (/api/photolist, /api/photo) exponerade
Size	9	Alla internetanvändare kan testa via URL

Threat Agent = (3+8+9+9)/4 = 7.25

Sårbarhetsfaktorer

Faktor	Poäng	Motivering
Ease of Discovery	7	Upptäcks via DevTools och URL manipulation
Ease of Exploit	8	Direkt i webbläsaren, URL kodning som %2e%2e fungerar
Awareness	8	Känd i OWASP Top 10 (A01:2025 Broken Access Control)

Vulnerability = (7+8+8)/3 = 7.7
Likelihood = (7.25+7.7)/2 = 7.5 → **Hög**

Impact bedömning
Teknisk påverkan

Faktor	**Poäng**	**Motivering**
Loss of Confidentiality	9	Full åtkomst till filer, inklusive källkod och konfig
Loss of Integrity	5	Ingen direkt ändring, men läckage möjliggör vidare attacker
Loss of Availability	3	Minimal, ingen nedtid
Loss of Accountability	7	Svårt att spåra utan loggning

Impact = (9+5+3+7)/4 = 6 → **Medel**

Slutsats
Hög Likelihood x Medel Impact = Hög risk. Kan leda till vidare kompromiss, men inte omedelbar dataförstöring. Affärspåverkan, exponering av potentiell känslig kod.

Riskbedömning för Monkeypatching MITM

Likelihood bedömning
Threat Agent faktorer

Faktor	Poäng	Motivering
Skill Level	5	Viss JS kunskap behövs för monkeypatching, guider finns
Motive	9	Häg ekonomisk vinning, köp till rabatterat pris
Opportunity	7	Kräver DevTools, tillgängligt för alla användare
Size	6	Specifik grupp. Användare med tekniskt intresse

Threat Agent = (5+9+7+6)/4 = 6.75

Sårbarhetsfaktorer

Faktor	Poäng	Motivering
Ease of Discovery	6	Upptäcks via inspektion av frontend kod
Ease of Exploit	6	Kräver konsol script, inga externa verktyg
Awareness	7	Känd i OWASP (A06:2025 Insecure Design)

Vulnerability = (6+6+7)/3 = 6.3
Likelihood = (6.75+6.3)2 = 6.5 → **Medel**

Impact bedömning
Teknisk påverkan

Faktor	Poäng	Motivering
Loss of Confidentiality	3	Minimal, ingen dataexponering
Loss of Integrity	9	Priser/rabatter manipuleras och kan leda till felaktiga köp om backend saknar validering
Loss of Availability	3	Ingen påverkan
Loss of Accountability	5	Delvis spårbart via orderloggar

Impact = (3+9+3+5)/4 = 5 → **Medel**

Slutsats
Medel Likelihood x Medel Impact = Medel risk (men blir **kritisk** i detta fall eftersom backend inte validerar priser). Affärspåverkan är en ekonomisk förlust per manipulerad order.

Sammanfattande Rangordning av Sårbarheter

Baserat på riskbedömningarna:

1. SQLi Workshop (**Kritisk**)
2. XSS Workshop (**Kritisk**)
3. Monkeypatching MITM (**Kritisk** eftersom det **saknas** backend validering)
4. Traversal Workshop (**Hög**)